CIA Part 1 – Questions 119–177

Brutally Hard: Judgment, Nuance & Standards Traps

CIA Study Prep

October 17, 2026

Instructions

Each question slide is followed by a separate answer/explanation slide.

These are deliberately harder than typical exam items: multi-issue stems, competing Standards, and nuanced "best" judgments.

Read every qualifier ("MOST," "LEAST," "FIRST," "BEST") before answering.

Several items have more than one defensible answer in practice — choose the one the Standards most clearly support.

Q119

Question: A CAE at a bank has been asked by the CEO to sit on the credit committee that approves large loans, arguing that "internal audit's presence will strengthen the control environment," and that the CAE will "have no vote, only observe." The CAE would attend weekly, receive the same credit papers as voting members, and be expected to comment on loan quality. The audit committee has not been consulted. Which is the MOST appropriate action for the CAE?

A. Accept, because a non-voting observer role cannot impair objectivity since the CAE does not approve loans.

B. Accept, because the CAE's presence strengthens the control environment and the audit committee can be informed later.

C. Decline the voting/decision role but potentially accept a clearly advisory, non-decision role with audit committee awareness and safeguards against self-review of credit decisions later audited.

D. Accept, but assign the future credit audit to a subordinate and document the arrangement in the workpapers.

Q119 – Answer & Explanation

Correct Answer: C

Why: Standards 1130 and 1130.A1/1130.A2 prohibit assuming management responsibilities and require safeguards where consulting/advisory roles create self-review threats. "Observer" roles that involve commenting on decisions and receiving decision papers can still create a self-review threat when those same decisions are later audited. The audit committee should be aware.

A wrong: Non-voting does not eliminate self-review; commenting on loan quality is participation in the decision process.

B wrong: Audit committee awareness cannot be deferred; functional reporting requires it.

D wrong: Delegating the audit does not cure the CAE's self-review threat, and mere documentation is not a safeguard.

Q120

Question: During an audit of a subsidiary, an internal auditor discovers that the subsidiary's CFO has been booking revenue on shipments to a related-party distributor that has no obligation to pay until the goods are resold to end customers, and that the subsidiary has a history of accepting returns from this distributor. The CFO states that "legal title transferred" and that the group policy permits recognition. The group policy is silent on this arrangement. Which conclusion is MOST appropriate for the auditor?

A. Revenue recognition is appropriate because legal title transferred and group policy is silent.

B. Revenue recognition is likely inappropriate because the substance of the arrangement (no obligation to pay until resale, return history) suggests control has not transferred; this is a potential financial reporting fraud indicator.

C. Revenue recognition is appropriate because the distributor is a related party and related-party sales are always recognized.

D. The auditor should defer to the CFO because revenue recognition is a management judgment.

Q120 – Answer & Explanation

Correct Answer: B

Why: Substance over form governs revenue recognition. A "sale" with no obligation to pay until resale and a return history is likely a consignment/channel-stuffing arrangement — a classic financial reporting fraud red flag. Silence in policy does not authorize improper recognition.

A wrong: Legal title is not determinative; substance governs.

B wrong: Related-party status does not make recognition automatically correct; it heightens scrutiny.

D wrong: Management judgment does not shield improper accounting from audit challenge.

Q121

Question: The CAE is finalizing the risk-based plan. The audit committee chair privately tells the CAE that the CEO has "verbally threatened" to cut the internal audit budget if the plan includes a review of a high-margin business unit run by the CEO's son-in-law. The audit committee chair asks the CAE to "handle it quietly." The business unit represents 20% of revenue and has never been audited. Which is the MOST appropriate action?

A. Remove the business unit from the plan to protect the audit budget and avoid conflict.

B. Keep the business unit in the plan based on risk, document the CEO's threat, and ensure the audit committee formally addresses the independence threat.

C. Refer the matter to the external auditor and take no further action.

D. Delay the audit for one year and revisit if the CEO's threat persists.

Q121 – Answer & Explanation

Correct Answer: B

Why: Standard 2010 requires a risk-based plan; Standards 1110/1111/1130 require the CAE to preserve independence and escalate threats. A CEO threat tied to audit coverage is a direct independence threat that must be documented and addressed with the audit committee, not resolved informally.

A wrong: Removing a material, never-audited unit because of a threat is caving to intimidation.

C wrong: External audit referral does not discharge the CAE's responsibility.

D wrong: Delay rewards intimidation and leaves a material risk uncovered.

Q122

Question: An auditor is testing a key automated control that calculates inventory obsolescence. The IT general controls over change management are weak: developers can promote code to production without independent testing, and the auditor cannot obtain a complete population of changes for the period. The auditor has limited IT expertise. Which approach is MOST appropriate?

A. Rely on the automated control because the calculation logic has not changed in three years per the IT director.

B. Conclude the automated control cannot be relied upon, expand substantive testing of obsolescence, and report the ITGC deficiency to the audit committee.

C. Perform a single walkthrough of the calculation and conclude the control is effective.

D. Ignore the ITGC weakness because the audit is of inventory, not IT.

Q122 – Answer & Explanation

Correct Answer: B

Why: Automated application controls depend on effective ITGCs (change management, access). Weak ITGCs and an incomplete change population mean the automated control cannot be relied upon; the auditor must expand substantive procedures and report the ITGC deficiency.

A wrong: "No change per the IT director" is unverified and insufficient given weak change controls.

C wrong: One walkthrough tests design/operation at a point in time, not reliability over the period.

D wrong: ITGCs are directly relevant to reliance on automated controls.

Q123

Question: An internal auditor is performing a consulting engagement to help management redesign the procurement approval workflow. During the engagement, the auditor learns that the current workflow has been intentionally bypassed by a senior manager to steer contracts to a favored vendor. Management asks the auditor to "keep this out of the consulting report" because the redesign will "fix it going forward." Which is the MOST appropriate action?

A. Omit the matter from the consulting report because the redesign will remediate it.

B. Report the matter through appropriate channels (e.g., CAE and audit committee) because it is a potential fraud/conflict-of-interest issue, even in a consulting engagement.

C. Include it only in a verbal aside to the engagement sponsor.

D. Defer reporting until the redesign is complete and re-audit the workflow.

Q123 – Answer & Explanation

Correct Answer: B

Why: The Code (Integrity) and Standards 1210.A2/2400 require reporting potential fraud/conflict-of-interest matters through appropriate channels regardless of engagement type. Future remediation does not excuse suppression of a known issue.

A wrong: Omission conceals a potential fraud.

C wrong: A verbal aside is not an appropriate reporting channel.

D wrong: Deferral risks concealment and delayed action.

Q124

Question: The CAE is conducting the annual assessment of the internal audit activity's conformance with the Standards. She finds that: (1) the audit plan is risk-based and approved by the audit committee; (2) engagements are documented and supervised; (3) the last external quality assessment was six years ago; (4) an engagement audited a process the engagement partner had designed two years earlier; and (5) the CAE reports functionally to the audit committee. Which issue is MOST significant for the conformance conclusion?

A. The audit plan's approval by the audit committee.

B. The late external quality assessment and the self-review engagement are both nonconformances that must be evaluated and reported.

C. The documentation and supervision of engagements.

D. The CAE's functional reporting line.

Q124 – Answer & Explanation

Correct Answer: B

Why: Standard 1312 requires external assessment at least every five years; Standard 1130.A1 prohibits auditing work the auditor previously designed/implemented (self-review). Both are nonconformances requiring evaluation and reporting under Standard 1320.

A wrong: Audit committee approval is a strength, not an issue.

C wrong: Documentation/supervision is a strength.

D wrong: Functional reporting to the audit committee is appropriate.

Q125

Question: An auditor is testing the completeness of recorded trade payables at a manufacturing company. The company uses a three-way match, but the auditor finds that 15% of receiving reports in the last month of the year have no matching invoice and no accrued liability. Management states that "goods in transit" are not recorded until invoiced, consistent with "historical practice." The auditor's tests of prior years did not identify this. Which conclusion and action are MOST appropriate?

A. The practice is acceptable because it is consistent with prior years and the auditor did not previously object.

B. Payables are likely understated; the auditor should quantify the effect, report the control weakness, and consider whether prior periods are also misstated.

C. The auditor should ignore the matter because goods in transit are not the company's liability.

D. The auditor should accept management's explanation because it is a "historical practice."

Q125 – Answer & Explanation

Correct Answer: B

Why: Goods received before year-end create a liability regardless of invoice receipt; failing to accrue understates payables. The auditor must quantify, report the control weakness, and consider prior-period implications (a possible prior-year error the auditor missed). Consistency and "historical practice" are not valid defenses.

A wrong: Prior non-detection does not legitimize the practice.

C wrong: Goods received are the company's liability even if in transit/invoiced later.

D wrong: Historical practice is not a basis for accepting misstatement.

Q126

Question: The CAE is evaluating whether to accept an engagement requested by the audit committee to review the CEO's expense reimbursements. The CEO is the CAE's administrative reporting line, approves the audit budget, and has previously commented negatively on audit findings about executives. The audit committee supports the engagement. Which is the MOST appropriate action?

A. Decline because the CEO is the administrative reporting line and any finding would be conflicted.

B. Accept the engagement, document the independence considerations, and ensure the audit committee provides functional oversight and receives the results directly.

C. Accept but assign the engagement to a new staff auditor to avoid the CAE's conflict.

D. Refer the engagement to the external auditor and take no further action.

Q126 – Answer & Explanation

Correct Answer: B

Why: The audit committee requested the engagement and provides functional oversight (Standards 1110/1111/1130). Administrative reporting to the CEO does not preclude auditing the CEO's expenses when the audit committee directs it and receives results directly. Safeguards must be documented.

A wrong: Declining would leave a governance-requested engagement unaddressed; functional oversight mitigates the threat.

C wrong: Assigning a junior auditor does not address the structural threat and may lack competence.

D wrong: Referral does not discharge internal audit's responsibility.

Q127

Question: An auditor is testing a sample of 40 manual journal entries above a threshold. The auditor finds 6 entries posted on a weekend by a user with "super user" access, all reversing accruals and increasing revenue, all lacking supporting documentation. The controller states the entries were "quarter-end true-ups" and that documentation is "being compiled." Which is the MOST appropriate next step?

A. Accept the controller's explanation and note that documentation is pending.

B. Treat the entries as high-risk, obtain support or escalate if unavailable, expand testing around super-user journal entries, and report the access/control weakness.

C. Delete the six entries from the sample as outliers.

D. Conclude the control is effective because only 6 of 40 were exceptions.

Q127 – Answer & Explanation

Correct Answer: B

Why: Weekend postings by a super user, reversing accruals, increasing revenue, and no support are classic management override/financial reporting fraud indicators. The auditor must investigate, escalate if support is absent, and address the super-user access weakness.

A wrong: Pending documentation is not evidence; the entries remain high-risk.

C wrong: Deleting outliers from a sample is improper.

D wrong: 15% exceptions on a key control is not effective operation.

Q128

Question: The CAE is asked by the CFO to "review the design" of a new revenue system before go-live and to "sign off that the design is adequate." The CFO states that sign-off is needed for the project steering committee. Which is the MOST appropriate response?

A. Provide the review and sign off as requested, since the CFO is a key stakeholder.

B. Provide advisory observations on design risks but decline to "sign off," making clear that internal audit does not approve management's design or assume management responsibility.

C. Decline any involvement because reviewing design impairs independence.

D. Sign off but disclose in the report that the sign-off is advisory only.

Q128 – Answer & Explanation

Correct Answer: B

Why: Standards 1130 and the consulting guidance permit advisory review but prohibit assuming management responsibility or approving management's work. "Sign-off" implies approval/ownership of the design, which is a management responsibility.

A wrong: Sign-off makes internal audit complicit in the design and creates self-review.

C wrong: Advisory review is permitted; total abstention is not required.

D wrong: A disclaimer does not cure the assumption of management responsibility.

Q129

Question: An auditor is evaluating the organization's fraud risk assessment for revenue. Management has identified "channel stuffing" as a risk but states that "our sales team is compensated on cash collection, not bookings, so the risk is mitigated." The auditor finds that sales contracts include extended payment terms and a right of return, and that the sales team receives bonuses on bookings with a clawback only after 12 months. Which conclusion is MOST appropriate?

A. The risk is adequately mitigated because compensation is based on cash collection.

B. The risk is not adequately mitigated; bookings-based bonuses with delayed clawbacks and extended terms/returns create incentive and opportunity for channel stuffing.

C. Channel stuffing is not a fraud risk in this industry.

D. The auditor should accept management's conclusion because compensation design is a management decision.

Q129 – Answer & Explanation

Correct Answer: B

Why: Incentives drive fraud. Bookings-based bonuses (even with delayed clawback), extended terms, and return rights create pressure and opportunity for channel stuffing. The "cash collection" claim is contradicted by the bonus structure.

A wrong: The bonus is on bookings, not cash; the claim is inconsistent with facts.

C wrong: Channel stuffing is a recognized revenue fraud scheme across industries.

D wrong: Compensation design is relevant evidence of fraud risk.

Q130

Question: The audit committee asks the CAE whether the organization's internal audit activity can rely on the work of the compliance function for an AML engagement. The compliance function: (1) has qualified staff, (2) reports to the CRO, (3) designed the AML controls, (4) tested them last year with no significant findings, and (5) is subject to regulatory examination. Which factor MOST limits reliance?

A. The compliance function's qualifications.

B. The compliance function's self-review (designing and testing the same controls).

C. The compliance function's reporting line to the CRO.

D. The regulatory examination of the compliance function.

Q130 – Answer & Explanation

Correct Answer: B

Why: Standard 2050 requires evaluating objectivity and competence. Designing and then testing the same controls is a self-review threat that most limits reliance, regardless of qualifications.

A wrong: Qualifications support reliance.

C wrong: CRO reporting is a factor but less significant than self-review.

D wrong: Regulatory examination is a positive, not a limitation.

Q131

Question: An auditor is evaluating a whistleblower complaint alleging that a plant manager is falsifying safety inspection records. The complaint was made anonymously to the hotline and includes specific dates and record numbers. The plant manager is a top performer and the plant is the company's most profitable. The CAE is asked by the COO to "let HR handle it informally." Which is the MOST appropriate action?

A. Allow HR to handle it informally because the COO requested it.

B. Treat the allegation as a significant matter: conduct a preliminary assessment, preserve records, and report to the audit committee as appropriate.

C. Confront the plant manager directly to get his side of the story.

D. Ignore the complaint because it is anonymous.

Q131 – Answer & Explanation

Correct Answer: B

Why: Specific, detailed allegations of falsified safety records are significant (legal, safety, and fraud implications). Internal audit should assess, preserve evidence, and escalate appropriately (Standards 1210.A2/2400). Informal HR handling and COO pressure do not override this.

A wrong: Informal handling risks suppression and evidence loss.

C wrong: Direct confrontation can tip off the subject and destroy evidence.

D wrong: Anonymity does not reduce the need to assess a specific allegation.

Q132

Question: The CAE is assessing whether the internal audit activity has adequate resources. The activity has 10 auditors, a flat budget, and an approved plan covering 60 engagements. During the year, two auditors resign and are replaced by one junior auditor; management also requests three unplanned engagements. The CAE does not inform the audit committee. Which statement is MOST accurate?

A. The CAE acted appropriately because resource issues are administrative.

B. The CAE should have communicated the resource shortfall and its effect on the plan to the audit committee, consistent with Standard 2030.

C. The CAE should have silently reduced the plan to match resources.

D. Resource adequacy is solely management's responsibility.

Q132 – Answer & Explanation

Correct Answer: B

Why: Standard 2030 requires the CAE to assess resource adequacy and communicate limitations to the board/audit committee, including the effect on the approved plan.

A wrong: Resource adequacy is a governance matter, not merely administrative.

C wrong: Silent reduction hides the impact from the audit committee.

D wrong: The CAE is responsible for assessing and communicating adequacy.

Q133

Question: An auditor is testing the organization's controls over the financial close. The ERP system allows the controller to post journal entries and then "lock" them so they cannot be viewed or edited, and the controller has used this feature for 12 large entries in the last quarter. The system logs the lock action but not the entry details. Which conclusion is MOST appropriate?

A. Controls are effective because the entries are locked and cannot be edited.

B. Controls are deficient; the lock feature conceals entries and prevents audit trail, creating a significant override risk.

C. Controls are effective because the controller is authorized to post entries.

D. The auditor should not assess system lock features.

Q133 – Answer & Explanation

Correct Answer: B

Why: A feature that hides entries and defeats the audit trail is itself a control weakness enabling override. Locking without visibility prevents review and detection.

A wrong: Locking without visibility is not a control benefit.

C wrong: Authorization does not address concealment.

D wrong: System features affecting the audit trail are a core audit area.

Q134

Question: The CAE is asked to evaluate the board's effectiveness. The board has a majority of independent directors, an independent audit committee, and a risk committee, but the CEO controls the agenda and board materials are distributed one day before meetings. Which conclusion is MOST appropriate?

A. Board effectiveness is adequate because of the independent committees.

B. Board effectiveness is likely impaired; CEO-controlled agendas and late materials undermine independent oversight despite structural independence.

C. Board effectiveness cannot be assessed by internal audit.

D. The auditor should ignore process issues because structure is what matters.

Q134 – Answer & Explanation

Correct Answer: B

Why: Independence requires both structure and process. CEO-controlled agendas and one-day materials prevent directors from preparing and challenging management, impairing effective oversight.

A wrong: Structure without effective process is insufficient.

C wrong: Internal audit assesses governance (Standard 2110).

D wrong: Process is central to effectiveness.

Q135

Question: An auditor is testing the organization's procurement controls for a large construction project. The auditor finds that change orders totaling 25% of the original contract value were approved by the project manager alone, with no independent review, and that the contractor is owned by the project manager's cousin. Which is the MOST appropriate conclusion?

A. Controls are effective because change orders are routine in construction.

B. Controls are deficient; unapproved change orders and a related-party contractor create significant fraud and cost-overrun risk.

C. Controls are effective because the project manager is accountable for the project.

D. The auditor should not assess change orders.

Q135 – Answer & Explanation

Correct Answer: B

Why: Large change orders approved solely by the project manager, combined with a related-party contractor, are major fraud red flags requiring independent approval and disclosure.

A wrong: Routine does not justify lack of independent approval.

C wrong: Accountability does not replace controls.

D wrong: Change orders are a core project audit area.

Q136

Question: An auditor is evaluating whether the organization's risk appetite statement is effectively operationalized. The board approved a statement saying the organization has "low appetite for compliance risk." However, the sales incentive plan pays commissions on contracts signed before compliance review, and compliance exceptions are routinely waived by the sales VP. Which is the MOST appropriate conclusion?

A. The risk appetite is operationalized because the board approved a statement.

B. The risk appetite is not operationalized; incentives and waiver authority contradict the stated appetite, indicating a weak risk culture.

C. Compliance risk is not relevant to sales incentives.

D. The auditor should accept the board's statement as sufficient evidence.

Q136 – Answer & Explanation

Correct Answer: B

Why: Risk appetite must be reflected in incentives, authorities, and enforcement. Commissions before compliance review and routine waivers directly contradict a "low appetite" for compliance risk.

A wrong: A statement alone does not operationalize appetite.

C wrong: Sales incentives directly drive compliance behavior.

D wrong: The auditor must assess whether behavior aligns with the statement.

Q137

Question: An auditor is testing the organization's controls over a new payment platform. The platform uses an external payment processor; the contract states the processor is responsible for fraud screening, but the organization has no right to audit the processor and has not obtained any assurance report. The processor handles 100% of customer payments. Which conclusion is MOST appropriate?

A. Controls are adequate because the contract assigns fraud screening to the processor.

B. Controls are deficient; reliance on a critical processor without audit rights or assurance creates significant fraud and operational risk.

C. The auditor should not assess third-party processors.

D. Contractual assignment of responsibility eliminates the need for oversight.

Q137 – Answer & Explanation

Correct Answer: B

Why: Outsourcing does not transfer oversight responsibility. No audit rights and no assurance report for a processor handling all payments is a significant control gap.

A wrong: Contractual assignment does not provide assurance.

C wrong: Third-party risk is a core audit area.

D wrong: The organization retains oversight responsibility.

Q138

Question: The CAE is evaluating a proposal to co-source internal audit with a firm that also provides consulting services to the organization's CFO. The firm would provide 40% of internal audit hours, including audits of financial reporting controls. Which is the MOST significant concern?

A. Cost of the co-sourcing arrangement.

B. The firm's independence/objectivity due to its consulting relationship with the CFO and the audit committee's oversight of the arrangement.

C. The firm's technical competence.

D. The size of the internal audit team.

Q138 – Answer & Explanation

Correct Answer: B

Why: The provider's consulting relationship with the CFO creates self-interest/self-review threats, especially for audits of financial reporting controls the firm may have consulted on. Independence and audit committee oversight are the key concerns.

A wrong: Cost is secondary to independence.

C wrong: Competence is presumed adequate; independence is the concern.

D wrong: Team size is not the key issue.

Q139

Question: An auditor is testing the completeness of revenue at a software company that sells multi-year subscriptions. The auditor finds that the company recognizes the full subscription amount at contract signing, while the contracts include cancellation rights and service obligations over three years. Management states that "the contracts are non-cancelable" but the contracts allow cancellation with a 10% fee. Which conclusion is MOST appropriate?

A. Revenue recognition is appropriate because the contracts are non-cancelable.

B. Revenue recognition is likely overstated; cancellation rights and multi-year service obligations require revenue to be recognized over time, not at signing.

C. Revenue recognition is appropriate because the company has a signed contract.

D. The auditor should accept management's statement because contracts are legal documents.

Q139 – Answer & Explanation

Correct Answer: B

Why: A 10% cancellation fee means the contract is not truly non-cancelable; revenue for multi-year subscription services should be recognized over the service period. Recognizing the full amount at signing overstates revenue.

A wrong: The cancellation right contradicts "non-cancelable."

C wrong: A signed contract does not determine the recognition pattern.

D wrong: Legal documents must be read for their substance.

Q140

Question: An auditor is evaluating the organization's cybersecurity incident response. The organization discovered a breach six months ago, did not notify regulators or affected customers, and has no documentation of the incident or remediation steps. The CISO states the breach was "contained" and that disclosure would harm the brand. Which conclusion is MOST appropriate?

A. Incident response is adequate because the breach was contained.

B. Incident response and governance are deficient; lack of documentation, notification, and remediation creates legal, regulatory, and reputational risk.

C. Breach notification is solely a legal matter outside internal audit's scope.

D. The auditor should accept the CISO's statement because disclosure could harm the brand.

Q140 – Answer & Explanation

Correct Answer: B

Why: Incident response requires documentation, assessment of notification obligations, and remediation. Non-disclosure and no documentation are significant governance/control deficiencies.

A wrong: Containment alone does not satisfy response requirements.

C wrong: Internal audit assesses compliance and governance, including breach response.

D wrong: Brand concerns do not override legal/regulatory obligations.

Q141

Question: The CAE is reviewing a draft engagement report that concludes a control is "effective" based on management's self-assessment and a walkthrough, even though the auditor's sample testing found a 6% deviation rate against a 5% tolerable rate. The engagement lead argues that the deviations were "immaterial" and that management has a remediation plan. Which action is MOST appropriate for the CAE?

A. Approve the report because management has a remediation plan.

B. Require the conclusion to reflect the deviation rate (control not operating effectively), ensure the finding is reported, and evaluate the sufficiency of the auditor's evidence.

C. Approve the report but add a footnote about the deviations.

D. Return the report to the auditor to reduce the sample size and retest.

Q141 – Answer & Explanation

Correct Answer: B

Why: A 6% deviation against a 5% tolerable rate means the control is not operating effectively; the conclusion must reflect the evidence (Standards 2320/2410). Remediation plans do not change the testing result.

A wrong: Remediation plans do not validate current effectiveness.

C wrong: A footnote does not correct an unsupported conclusion.

D wrong: Reducing the sample to retest is results-shopping.

Q142

Question: An auditor discovers that the organization's treasury department has been using a single counterparty for all foreign exchange hedges, that the counterparty is owned by the treasurer's brother, and that hedge pricing is consistently 2–3% worse than market. The treasurer states the pricing is "within tolerance." Which is the MOST appropriate conclusion?

A. Controls are effective because pricing is within tolerance.

B. Controls are deficient; related-party concentration and unfavorable pricing create significant fraud/conflict-of-interest risk requiring investigation and reporting.

C. The auditor should accept the treasurer's statement because he is accountable for treasury.

D. Related-party transactions are outside the scope of internal audit.

Q142 – Answer & Explanation

Correct Answer: B

Why: Single-counterparty concentration, a family relationship, and consistently unfavorable pricing are classic fraud/conflict-of-interest indicators. "Within tolerance" does not address the conflict.

A wrong: Tolerance does not cure the conflict.

C wrong: Accountability does not replace independent review.

D wrong: Related-party transactions are a core audit area.

Q143

Question: The CAE is evaluating whether the internal audit activity can rely on a specialist's work in a complex valuation engagement. The specialist is a qualified appraiser, was engaged by management, is independent of the auditee's operations, and used assumptions that management approved. Which factor MOST limits reliance?

A. The specialist's qualifications.

B. The specialist's independence from internal audit and the fact that management approved the assumptions.

C. The complexity of the valuation.

D. The cost of the specialist.

Q143 – Answer & Explanation

Correct Answer: B

Why: When relying on a specialist, the auditor must evaluate competence, objectivity, and the appropriateness of the specialist's assumptions. Management-approved assumptions and engagement by management create objectivity concerns that most limit reliance.

A wrong: Qualifications support reliance.

C wrong: Complexity is why a specialist is used.

D wrong: Cost is not a reliance criterion.

Q144

Question: An auditor is testing the organization's controls over the vendor master file. The auditor finds that 30 vendors share the same bank account, 12 of those were added by the same clerk, and 8 are registered at a virtual office address. The clerk states the vendors are "legitimate suppliers." Which is the MOST appropriate action?

A. Accept the clerk's explanation because the vendors are described as suppliers.

B. Investigate the vendors as a potential shell-company/kickback scheme, preserve evidence, and report through appropriate channels.

C. Remove the suspicious vendors from the master file personally.

D. Ignore the findings because virtual offices are common.

Q144 – Answer & Explanation

Correct Answer: B

Why: Shared bank accounts, a single clerk adding vendors, and virtual addresses are classic shell-company/kickback red flags. Investigate, preserve evidence, and report; do not alter records.

A wrong: Labels do not explain the red flags.

C wrong: Internal audit should not make management changes.

D wrong: Ignoring red flags is improper.

Q145

Question: The CAE is assessing the organization's risk management for a major acquisition. Management's integration plan addresses finance and operations but not culture, IT systems, or third-party contracts. The acquisition is the largest in the organization's history. Which conclusion is MOST appropriate?

A. Integration risk management is adequate because finance and operations are covered.

B. Integration risk management is deficient; culture, IT, and third-party contract risks are significant and unaddressed.

C. Acquisition integration is outside internal audit's scope.

D. The auditor should ignore culture because it cannot be measured.

Q145 – Answer & Explanation

Correct Answer: B

Why: Acquisition integration risk includes culture, IT, and third-party contracts, all of which can materially affect deal success. Omitting them is a significant gap.

A wrong: Partial coverage is not adequate for a major acquisition.

C wrong: Acquisition integration is a core audit area.

D wrong: Culture is a recognized integration risk.

Q146

Question: An auditor is evaluating the organization's controls over the use of spreadsheets for a critical regulatory capital calculation. The spreadsheet has documented formulas, version control, and independent review, but it is maintained by a single analyst with no backup, and the analyst is the only person who understands the model. Which conclusion is MOST appropriate?

A. Controls are effective because the spreadsheet has documented formulas, version control, and review.

B. Controls are partially effective but have a key-person risk; lack of backup and single-person knowledge threaten continuity and create operational risk.

C. Controls are fully effective because the analyst is experienced.

D. The auditor should not assess spreadsheet controls.

Q146 – Answer & Explanation

Correct Answer: B

Why: Documented formulas, version control, and review are positive, but single-person dependency and no backup create key-person and continuity risk for a critical regulatory calculation.

A wrong: Key-person risk undermines effectiveness.

C wrong: Experience does not eliminate key-person risk.

D wrong: Spreadsheet controls are a valid audit area.

Q147

Question: The CAE is asked by the audit committee to evaluate whether the organization's fraud risk assessment is "adequate." Management's assessment covers asset misappropriation and corruption but explicitly excludes financial statement fraud "because the external auditor covers that." Which is the MOST appropriate conclusion?

A. The assessment is adequate because the external auditor covers financial statement fraud.

B. The assessment is deficient; financial statement fraud is a management and internal audit responsibility and cannot be delegated to the external auditor.

C. Financial statement fraud is not a fraud risk.

D. The auditor should accept the exclusion because it is documented.

Q147 – Answer & Explanation

Correct Answer: B

Why: Financial statement fraud is a core fraud risk that management must assess and internal audit must consider (Standard 1210.A2). External audit does not eliminate management's responsibility.

A wrong: External audit coverage does not transfer management responsibility.

C wrong: Financial statement fraud is a recognized fraud category.

D wrong: Documentation does not make an omission adequate.

Q148

Question: An auditor is testing the organization's controls over the financial close. The auditor finds that the same individual prepares, reviews, and posts consolidation entries, and that the individual has system access to override the consolidation. Which conclusion is MOST appropriate?

A. Controls are effective because the individual is experienced.

B. Controls are deficient; incompatible duties and override access create a significant risk of undetected error/fraud.

C. Controls are effective because consolidation is routine.

D. The auditor should not assess the financial close.

Q148 – Answer & Explanation

Correct Answer: B

Why: Combining prepare/review/post and override access is a severe segregation-of-duties and override risk.

A wrong: Experience is not a control.

C wrong: Routine processes can still be manipulated.

D wrong: Financial close is a core audit area.

Q149

Question: The CAE is evaluating the organization's cybersecurity governance. The organization has no board-level cybersecurity expertise, no regular cybersecurity reporting to the board, and no incident response plan. Which conclusion is MOST appropriate?

A. Cybersecurity governance is adequate because IT handles security.

B. Cybersecurity governance is deficient; board oversight, regular reporting, and an incident response plan are essential.

C. Cybersecurity is purely an IT issue, not a governance issue.

D. The auditor should not assess cybersecurity.

Q149 – Answer & Explanation

Correct Answer: B

Why: Cybersecurity is a board-level governance risk. Lack of expertise, reporting, and an incident response plan are significant governance deficiencies.

A wrong: Security is not solely an IT issue; governance oversight is required.

C wrong: Cybersecurity is a governance and enterprise risk.

D wrong: Internal audit assesses cybersecurity governance.

Q150

Question: An auditor is evaluating the organization's fraud risk assessment. Management's assessment is based solely on a brainstorming session with the CFO and controller, with no input from operations, sales, or IT, and no consideration of fraud schemes specific to the industry. Which conclusion is MOST appropriate?

A. The fraud risk assessment is adequate because senior finance staff participated.

B. The fraud risk assessment is deficient; it lacks cross-functional input and industry-specific fraud schemes.

C. The fraud risk assessment is adequate because brainstorming is a recognized technique.

D. Fraud risk assessment is not an internal audit concern.

Q150 – Answer & Explanation

Correct Answer: B

Why: Effective fraud risk assessment requires cross-functional input and consideration of industry-specific schemes. A finance-only brainstorm is insufficient.

A wrong: Finance-only input is too narrow.

C wrong: Brainstorming is useful but must be broad and informed.

D wrong: Internal audit assesses fraud risk (Standard 1210.A2).

Q151

Question: The CAE is assessing the organization's internal control framework. The organization has a strong control environment and strong control activities but no monitoring activities and no information/communication process. Which conclusion is MOST appropriate?

A. The internal control framework is effective because the control environment and activities are strong.

B. The internal control framework is incomplete; all five COSO components (including monitoring and information/communication) are necessary.

C. Monitoring and information/communication are optional.

D. Only control activities matter.

Q151 – Answer & Explanation

Correct Answer: B

Why: COSO requires all five components: control environment, risk assessment, control activities, information/communication, and monitoring. Missing components make the framework incomplete.

A wrong: Two components do not make a complete framework.

C wrong: All components are required.

D wrong: Control activities alone are insufficient.

Q152

Question: An auditor is testing the organization's controls over the purchase of consulting services. The auditor finds that the same manager selects the consultant, negotiates the contract, approves the invoice, and confirms receipt of services, with no independent review. Which conclusion is MOST appropriate?

A. Controls are effective because the manager is accountable for results.

B. Controls are deficient; the manager has incompatible duties (selection, negotiation, approval, receipt) with no independent review.

C. Controls are effective because consulting services are intangible.

D. The auditor should not assess consulting purchases.

Q152 – Answer & Explanation

Correct Answer: B

Why: Combining selection, negotiation, approval, and receipt of services creates a significant segregation-of-duties weakness and fraud risk.

A wrong: Accountability is not a control.

C wrong: Intangibility does not reduce the need for controls.

D wrong: Consulting purchases are a legitimate audit area.

Q153

Question: The CAE is evaluating the organization's risk response to a significant cybersecurity risk. Management has purchased cyber insurance but has not implemented basic security controls (patching, access management, monitoring). Which conclusion is MOST appropriate?

A. The risk response is adequate because insurance transfers the risk.

B. The risk response is inadequate; insurance transfers financial impact but does not reduce the likelihood of a breach, and basic controls are missing.

C. Insurance eliminates the need for controls.

D. Cybersecurity risk is not an internal audit concern.

Q153 – Answer & Explanation

Correct Answer: B

Why: Insurance is a risk-sharing response, not a substitute for preventive/detective controls. Basic security controls are essential to reduce likelihood.

A wrong: Insurance does not prevent breaches.

C wrong: Insurance does not eliminate the need for controls.

D wrong: Cybersecurity is a core internal audit area.

Q154

Question: An auditor is assessing the organization's use of a whistleblower hotline. The hotline is outsourced to an independent provider, reports go directly to the audit committee, and the audit committee reviews all reports. However, no reports have been filed in two years, and employee surveys indicate fear of retaliation. Which conclusion is MOST appropriate?

A. The hotline is effective because it is independent and reports to the audit committee.

B. The hotline may be underutilized due to fear of retaliation; the organization should address the retaliation risk and promote the hotline.

C. Zero reports prove the organization is ethical.

D. The auditor should ignore employee surveys.

Q154 – Answer & Explanation

Correct Answer: B

Why: A hotline's effectiveness depends on trust and non-retaliation. Zero reports combined with fear of retaliation suggests underutilization and a culture problem.

A wrong: Structure alone is insufficient.

C wrong: Zero reports may indicate fear, not ethics.

D wrong: Surveys provide relevant culture evidence.

Q155

Question: The CAE is asked to evaluate whether the organization's board has effective oversight of risk. The board receives a quarterly risk report that is prepared by management and contains only risk status ("green") with no details on emerging risks or risk appetite breaches. Which conclusion is MOST appropriate?

A. Board risk oversight is effective because the board receives a quarterly report.

B. Board risk oversight is likely ineffective; the report lacks detail, emerging risks, and appetite breach information.

C. Risk reporting is management's responsibility, not the board's.

D. The auditor should not assess board risk oversight.

Q155 – Answer & Explanation

Correct Answer: B

Why: Effective board risk oversight requires transparent, detailed reporting on emerging risks and appetite breaches. A "green-only" summary impairs oversight.

A wrong: Receiving a report is not the same as effective oversight.

C wrong: The board is responsible for oversight.

D wrong: Internal audit assesses governance/risk oversight.

Q156

Question: An auditor is testing the organization's controls over the sales commission process. The auditor finds that sales managers can adjust commission rates and approve their own adjustments, with no independent review. Which conclusion is MOST appropriate?

A. Controls are effective because sales managers understand commissions.

B. Controls are deficient; sales managers can adjust rates and approve their own changes, creating a significant fraud risk.

C. Controls are effective because commission adjustments are rare.

D. The auditor should not assess sales commissions.

Q156 – Answer & Explanation

Correct Answer: B

Why: The ability to adjust rates and self-approve creates a significant fraud risk (self-dealing). Independent review is required.

A wrong: Knowledge is not a control.

C wrong: Rarity does not reduce the fraud risk.

D wrong: Commissions are a core audit area.

Q157

Question: The CAE is evaluating the organization's compliance with its own code of conduct. The CAE finds that senior executives routinely accept expensive gifts from vendors and that no one has been disciplined. Which conclusion is MOST appropriate?

A. The code of conduct is effective because it is written.

B. The code of conduct is not effective; senior executive behavior and lack of enforcement undermine the code.

C. Gifts are acceptable if they are expensive.

D. The auditor should ignore executive behavior.

Q157 – Answer & Explanation

Correct Answer: B

Why: Tone at the top and enforcement are essential. Senior executives accepting gifts without consequences undermine the code's effectiveness.

A wrong: A written code without enforcement is ineffective.

C wrong: Expensive gifts create significant conflicts.

D wrong: Executive behavior is a key governance indicator.

Q158

Question: An auditor is assessing the organization's controls over the use of spreadsheets in financial reporting. The auditor finds that a critical revenue calculation is performed in a spreadsheet with no version control, no formula documentation, and no independent review. Which conclusion is MOST appropriate?

A. Controls are adequate because spreadsheets are common tools.

B. Controls are deficient; critical spreadsheets require version control, documentation, and independent review.

C. Spreadsheets are always inappropriate for financial reporting.

D. The auditor should not assess spreadsheet controls.

Q158 – Answer & Explanation

Correct Answer: B

Why: Critical spreadsheets are high-risk end-user computing tools requiring version control, documentation, and review to prevent errors/fraud.

A wrong: Common use does not reduce risk.

C wrong: Spreadsheets can be used with adequate controls.

D wrong: Spreadsheet controls are a valid audit area.

Q159

Question: The CAE is evaluating the organization's risk management for a major IT system implementation. The project has no risk register, no steering committee, and no independent oversight; the project manager reports only to the CIO. Which conclusion is MOST appropriate?

A. Project risk management is adequate because the CIO is accountable.

B. Project risk management is deficient; major IT projects require a risk register, steering committee, and independent oversight.

C. IT projects do not require risk management.

D. The auditor should not assess IT project risk.

Q159 – Answer & Explanation

Correct Answer: B

Why: Major IT projects require structured risk management, governance (steering committee), and independent oversight to manage cost, schedule, and risk.

A wrong: CIO accountability alone is insufficient.

C wrong: All projects require risk management.

D wrong: IT project risk is a core audit area.

Q160

Question: An auditor is testing the organization's controls over journal entries. The auditor finds that 20 large manual entries were posted at year-end by the controller with descriptions such as "reclass" and "true-up," and that supporting documentation cannot be located. Which action is MOST appropriate?

A. Accept the entries because the controller is authorized.

B. Investigate the entries, request support, and report the lack of documentation as a significant deficiency.

C. Delete the entries from the system.

D. Ignore the entries because they are year-end adjustments.

Q160 – Answer & Explanation

Correct Answer: B

Why: Large manual year-end entries by senior management are a high fraud risk area. Lack of support is a significant deficiency requiring investigation and reporting.

A wrong: Authorization does not eliminate the need for support.

C wrong: Internal audit should not alter records.

D wrong: Year-end adjustments require documentation.

Q161

Question: The CAE is evaluating the organization's use of key risk indicators (KRIs). The organization tracks revenue, profit, and customer satisfaction but has no KRIs for compliance, cybersecurity, or supply chain risk. Which conclusion is MOST appropriate?

A. KRI coverage is adequate because financial and customer metrics are tracked.

B. KRI coverage is incomplete; the organization lacks KRIs for significant risk areas (compliance, cybersecurity, supply chain).

C. KRIs are optional for all organizations.

D. The auditor should not assess KRIs.

Q161 – Answer & Explanation

Correct Answer: B

Why: KRIs should cover the organization's significant risks. Omitting compliance, cybersecurity, and supply chain KRIs leaves key risks unmonitored.

A wrong: Financial/customer metrics alone are insufficient.

C wrong: KRIs are an important monitoring tool.

D wrong: Internal audit assesses risk monitoring.

Q162

Question: An auditor is evaluating the organization's controls over the financial close. The auditor finds that the same individual prepares, reviews, and posts consolidation entries, and that the individual has system access to override the consolidation. Which conclusion is MOST appropriate?

A. Controls are effective because the individual is experienced.

B. Controls are deficient; incompatible duties and override access create a significant risk of undetected error/fraud.

C. Controls are effective because consolidation is routine.

D. The auditor should not assess the financial close.

Q162 – Answer & Explanation

Correct Answer: B

Why: Combining prepare/review/post and override access is a severe segregation-of-duties and override risk.

A wrong: Experience is not a control.

C wrong: Routine processes can still be manipulated.

D wrong: Financial close is a core audit area.

Q163

Question: The CAE is evaluating the organization's risk appetite for cybersecurity. The board has stated "zero tolerance for data breaches," but management has not funded basic security controls and has accepted known vulnerabilities. Which conclusion is MOST appropriate?

A. Risk appetite and behavior are aligned because the board stated zero tolerance.

B. There is a disconnect between stated risk appetite and actual behavior; the organization is not resourcing controls consistent with its appetite.

C. Cybersecurity risk is not a governance issue.

D. The auditor should ignore the disconnect.

Q163 – Answer & Explanation

Correct Answer: B

Why: Risk appetite must be supported by resources and actions. A stated zero tolerance without funding/controls indicates misalignment and a weak risk culture.

A wrong: Statements without action are not alignment.

C wrong: Cybersecurity is a governance risk.

D wrong: Misalignment is a reportable governance weakness.

Q164

Question: An auditor is testing the organization's controls over the use of artificial intelligence (AI) in credit decisions. The auditor finds that the AI model was developed by an external vendor, has not been validated, and that management cannot explain the model's logic. Which conclusion is MOST appropriate?

A. Controls are adequate because the model was developed by a vendor.

B. Controls are deficient; unvalidated AI models with unexplainable logic create significant model, compliance, and reputational risk.

C. AI models do not require validation.

D. The auditor should not assess AI models.

Q164 – Answer & Explanation

Correct Answer: B

Why: AI models used in credit decisions require validation, documentation, and explainability to manage model risk and regulatory compliance.

A wrong: Vendor development does not eliminate the need for validation.

C wrong: AI models require validation.

D wrong: AI risk is a core internal audit area.

Q165

Question: The CAE is evaluating the organization's fraud hotline. The hotline is managed by the internal audit function, reports go directly to the CAE, and the CAE investigates all reports. Which statement is MOST accurate?

A. The hotline is effective because internal audit is independent.

B. The hotline may create an independence/self-review issue if internal audit investigates reports about its own function; oversight by the audit committee is important.

C. The hotline is ineffective because internal audit manages it.

D. Hotlines should never be managed by internal audit.

Q165 – Answer & Explanation

Correct Answer: B

Why: Internal audit managing a hotline is common, but reports involving internal audit itself create a self-review threat. Audit committee oversight and escalation protocols are important safeguards.

A wrong: Independence alone does not resolve self-review for reports about internal audit.

C wrong: Internal audit management is not inherently ineffective.

D wrong: Internal audit can manage hotlines with safeguards.

Q166

Question: An auditor is testing the organization's controls over the financial close. The auditor finds that the controller prepares, reviews, and posts consolidation entries, and that the controller has system access to override the consolidation. Which conclusion is MOST appropriate?

A. Controls are effective because the controller is experienced.

B. Controls are deficient; incompatible duties and override access create a significant risk of undetected error/fraud.

C. Controls are effective because consolidation is routine.

D. The auditor should not assess the financial close.

Q166 – Answer & Explanation

Correct Answer: B

Why: Combining prepare/review/post and override access is a severe segregation-of-duties and override risk.

A wrong: Experience is not a control.

C wrong: Routine processes can still be manipulated.

D wrong: Financial close is a core audit area.

Q167

Question: The CAE is evaluating the organization's risk appetite for cybersecurity. The board has stated "zero tolerance for data breaches," but management has not funded basic security controls and has accepted known vulnerabilities. Which conclusion is MOST appropriate?

A. Risk appetite and behavior are aligned because the board stated zero tolerance.

B. There is a disconnect between stated risk appetite and actual behavior; the organization is not resourcing controls consistent with its appetite.

C. Cybersecurity risk is not a governance issue.

D. The auditor should ignore the disconnect.

Q167 – Answer & Explanation

Correct Answer: B

Why: Risk appetite must be supported by resources and actions. A stated zero tolerance without funding/controls indicates misalignment and a weak risk culture.

A wrong: Statements without action are not alignment.

C wrong: Cybersecurity is a governance risk.

D wrong: Misalignment is a reportable governance weakness.

Q168

Question: An auditor is testing the organization's controls over related-party transactions. The auditor finds that the CEO's spouse owns a consulting firm that received $3 million in contracts, and that the transactions were not disclosed to the board or in the financial statements. Which conclusion is MOST appropriate?

A. The transactions are acceptable because the firm is competitive.

B. The transactions represent a significant control and disclosure deficiency; related-party transactions must be identified, approved, and disclosed.

C. Related-party transactions are outside the scope of internal audit.

D. The auditor should ignore the transactions because they involve a spouse.

Q168 – Answer & Explanation

Correct Answer: B

Why: Related-party transactions require identification, independent approval, and disclosure. Undisclosed transactions with the CEO's spouse's firm are a significant governance/control failure.

A wrong: Competitiveness does not eliminate disclosure requirements.

C wrong: Related-party transactions are a core audit area.

D wrong: Spousal relationships can be fraud indicators.

Q169

Question: The CAE is evaluating the organization's cybersecurity governance. The organization has no board-level cybersecurity expertise, no regular cybersecurity reporting to the board, and no incident response plan. Which conclusion is MOST appropriate?

A. Cybersecurity governance is adequate because IT handles security.

B. Cybersecurity governance is deficient; board oversight, regular reporting, and an incident response plan are essential.

C. Cybersecurity is purely an IT issue, not a governance issue.

D. The auditor should not assess cybersecurity.

Q169 – Answer & Explanation

Correct Answer: B

Why: Cybersecurity is a board-level governance risk. Lack of expertise, reporting, and an incident response plan are significant governance deficiencies.

A wrong: Security is not solely an IT issue; governance oversight is required.

C wrong: Cybersecurity is a governance and enterprise risk.

D wrong: Internal audit assesses cybersecurity governance.

Q170

Question: An auditor is evaluating the organization's fraud risk assessment. Management's assessment is based solely on a brainstorming session with the CFO and controller, with no input from operations, sales, or IT, and no consideration of fraud schemes specific to the industry. Which conclusion is MOST appropriate?

A. The fraud risk assessment is adequate because senior finance staff participated.

B. The fraud risk assessment is deficient; it lacks cross-functional input and industry-specific fraud schemes.

C. The fraud risk assessment is adequate because brainstorming is a recognized technique.

D. Fraud risk assessment is not an internal audit concern.

Q170 – Answer & Explanation

Correct Answer: B

Why: Effective fraud risk assessment requires cross-functional input and consideration of industry-specific schemes. A finance-only brainstorm is insufficient.

A wrong: Finance-only input is too narrow.

C wrong: Brainstorming is useful but must be broad and informed.

D wrong: Internal audit assesses fraud risk (Standard 1210.A2).

Q171

Question: The CAE is assessing the organization's internal control framework. The organization has a strong control environment and strong control activities but no monitoring activities and no information/communication process. Which conclusion is MOST appropriate?

A. The internal control framework is effective because the control environment and activities are strong.

B. The internal control framework is incomplete; all five COSO components (including monitoring and information/communication) are necessary.

C. Monitoring and information/communication are optional.

D. Only control activities matter.

Q171 – Answer & Explanation

Correct Answer: B

Why: COSO requires all five components: control environment, risk assessment, control activities, information/communication, and monitoring. Missing components make the framework incomplete.

A wrong: Two components do not make a complete framework.

C wrong: All components are required.

D wrong: Control activities alone are insufficient.

Q172

Question: An auditor is testing the organization's controls over the purchase of consulting services. The auditor finds that the same manager selects the consultant, negotiates the contract, approves the invoice, and confirms receipt of services, with no independent review. Which conclusion is MOST appropriate?

A. Controls are effective because the manager is accountable for results.

B. Controls are deficient; the manager has incompatible duties (selection, negotiation, approval, receipt) with no independent review.

C. Controls are effective because consulting services are intangible.

D. The auditor should not assess consulting purchases.

Q172 – Answer & Explanation

Correct Answer: B

Why: Combining selection, negotiation, approval, and receipt of services creates a significant segregation-of-duties weakness and fraud risk.

A wrong: Accountability is not a control.

C wrong: Intangibility does not reduce the need for controls.

D wrong: Consulting purchases are a legitimate audit area.

Q173

Question: The CAE is evaluating the organization's risk response to a significant cybersecurity risk. Management has purchased cyber insurance but has not implemented basic security controls (patching, access management, monitoring). Which conclusion is MOST appropriate?

A. The risk response is adequate because insurance transfers the risk.

B. The risk response is inadequate; insurance transfers financial impact but does not reduce the likelihood of a breach, and basic controls are missing.

C. Insurance eliminates the need for controls.

D. Cybersecurity risk is not an internal audit concern.

Q173 – Answer & Explanation

Correct Answer: B

Why: Insurance is a risk-sharing response, not a substitute for preventive/detective controls. Basic security controls are essential to reduce likelihood.

A wrong: Insurance does not prevent breaches.

C wrong: Insurance does not eliminate the need for controls.

D wrong: Cybersecurity is a core internal audit area.

Q174

Question: An auditor is assessing the organization's use of a whistleblower hotline. The hotline is outsourced to an independent provider, reports go directly to the audit committee, and the audit committee reviews all reports. However, no reports have been filed in two years, and employee surveys indicate fear of retaliation. Which conclusion is MOST appropriate?

A. The hotline is effective because it is independent and reports to the audit committee.

B. The hotline may be underutilized due to fear of retaliation; the organization should address the retaliation risk and promote the hotline.

C. Zero reports prove the organization is ethical.

D. The auditor should ignore employee surveys.

Q174 – Answer & Explanation

Correct Answer: B

Why: A hotline's effectiveness depends on trust and non-retaliation. Zero reports combined with fear of retaliation suggests underutilization and a culture problem.

A wrong: Structure alone is insufficient.

C wrong: Zero reports may indicate fear, not ethics.

D wrong: Surveys provide relevant culture evidence.

Q175

Question: The CAE is asked to evaluate whether the organization's board has effective oversight of risk. The board receives a quarterly risk report that is prepared by management and contains only risk status ("green") with no details on emerging risks or risk appetite breaches. Which conclusion is MOST appropriate?

A. Board risk oversight is effective because the board receives a quarterly report.

B. Board risk oversight is likely ineffective; the report lacks detail, emerging risks, and appetite breach information.

C. Risk reporting is management's responsibility, not the board's.

D. The auditor should not assess board risk oversight.

Q175 – Answer & Explanation

Correct Answer: B

Why: Effective board risk oversight requires transparent, detailed reporting on emerging risks and appetite breaches. A "green-only" summary impairs oversight.

A wrong: Receiving a report is not the same as effective oversight.

C wrong: The board is responsible for oversight.

D wrong: Internal audit assesses governance/risk oversight.

Q176

Question: An auditor is testing the organization's controls over the sales commission process. The auditor finds that sales managers can adjust commission rates and approve their own adjustments, with no independent review. Which conclusion is MOST appropriate?

A. Controls are effective because sales managers understand commissions.

B. Controls are deficient; sales managers can adjust rates and approve their own changes, creating a significant fraud risk.

C. Controls are effective because commission adjustments are rare.

D. The auditor should not assess sales commissions.

Q176 – Answer & Explanation

Correct Answer: B

Why: The ability to adjust rates and self-approve creates a significant fraud risk (self-dealing). Independent review is required.

A wrong: Knowledge is not a control.

C wrong: Rarity does not reduce the fraud risk.

D wrong: Commissions are a core audit area.

Q177

Question: The CAE is evaluating the organization's compliance with its own code of conduct. The CAE finds that senior executives routinely accept expensive gifts from vendors and that no one has been disciplined. Which conclusion is MOST appropriate?

A. The code of conduct is effective because it is written.

B. The code of conduct is not effective; senior executive behavior and lack of enforcement undermine the code.

C. Gifts are acceptable if they are expensive.

D. The auditor should ignore executive behavior.

Q177 – Answer & Explanation

Correct Answer: B

Why: Tone at the top and enforcement are essential. Senior executives accepting gifts without consequences undermine the code's effectiveness.

A wrong: A written code without enforcement is ineffective.

C wrong: Expensive gifts create significant conflicts.

D wrong: Executive behavior is a key governance indicator.

End

End of Questions 119–177

Review, repeat, and mark weak areas.